

NEWSLETTER N. 520 of March 28, 2024

Labor: Privacy Authority says no to the use of facial recognition for attendance control

Transport: Privacy Authority, more protections for subscriber data

Websites and apps for contact between doctor and patient: the Authority's guidelines

Intercepts, Privacy Authority: green light for the inter-district digital archive

****Labor: Privacy Authority says no to the use of facial recognition for attendance control****

Five companies fined for unlawfully processing biometric data

Facial recognition for monitoring attendance in the workplace violates employees' privacy. Currently, there is no regulation that allows the use of biometric data, as provided for in the Regulation, to carry out such activities. For this reason, the Privacy Authority has fined five companies - engaged in various capacities at the same waste disposal site - with fines of 70,000, 20,000, 6,000, 5,000, and 2,000 euros, for unlawfully processing the biometric data of a large number of workers. [SEE DECISIONS doc. web n. 9995680, 9995701, 9995741, 9995762, 9995785]

The Authority, which intervened following complaints from several employees, also highlighted the specific risks to workers' rights associated with the use of facial recognition systems, in light of the rules and guarantees provided both in national and European law.

From the inspection activity of the Authority, carried out in collaboration with the Special Privacy and Technological Fraud Unit of the Guardia di Finanza, further violations by the companies also emerged. In particular, the Authority found that three companies had shared the same biometric detection system for more than a year, moreover without having adopted adequate technical and security measures. Furthermore, the same "system," deemed unlawful by the Authority, was used at nine other locations where one of the sanctioned companies operated. Finally, the companies had not provided clear and detailed information to the workers nor had they conducted the impact assessment required by privacy regulations.

According to the Authority, the companies should have more appropriately used less invasive systems to monitor the presence of their employees and collaborators in the workplace (such as, for example, badges). In addition to the payment of fines, the Authority ordered the deletion of the unlawfully collected data.

****Transport: Privacy Authority, more protections for subscriber data****

A company fined for collecting invalid marketing consents

Even when we subscribe to transport services, we have the right to make free choices regarding the processing of our data.

The Privacy Authority has fined a transport company in Emilia Romagna 50,000 euros for using a subscription form for local public transport services that did not comply with data protection regulations.

The Authority's investigation, which was initiated following a report, found that the information provided to passengers at the time of subscription was lacking many essential elements, preventing them from giving free, specific, and informed consent.

The subscription card issuance form did not allow travelers to distinguish between mandatory and optional data (such as mobile phone number and email address) and did not clearly inform users of their right to object to processing for direct marketing purposes.

The company, which serves a significant user base, also had not reviewed and updated, by the effective date of the European privacy Regulation, either the data processing information and the subscription card request form or its internal policies regarding data retention.

In addition to the fine, the Authority imposed a ban on the transport company from processing users' data for marketing purposes and sending communications regarding the status of the transport service, based on data collected without appropriate information and on the basis of invalid consents. Furthermore, the Company must provide all interested parties with a new information notice on the processing of personal data that complies with the requirements set out by the EU Regulation, making it available on its official website, at its headquarters and sales points, as well as providing it to each interested party at the first available opportunity for contact.

****Websites and apps for contact between doctor and patient: the Authority's guidelines****

Concrete assistance from the Privacy Authority for apps and websites that connect patients with healthcare professionals, including general practitioners.

****General and the pediatricians of free choice who offer to users and doctors services such as the choice of the professional, the booking of visits, the sending and archiving of health documents. The Guarantor has published a document in 10 points indicating the obligations and requirements to be respected when processing such sensitive personal data. Through digital platforms, which in most cases are operated by companies established in European countries other than Italy or in third countries, both personal and health data of patients are used for multiple purposes by various parties involved in the processing operations and who may assume different roles in data protection (data controller, joint controller, and data processor). The compendium provides clarifications regarding three macro types of processing: patient data, necessary to offer them services also of an administrative nature related to the requested healthcare service (e.g., account creation, booking a medical visit); personal data of healthcare professionals processed for various purposes (e.g., management of the doctor's schedule and user reviews); health data of patients, processed for diagnostic and care purposes (e.g., sharing of health documents such as prescriptions or reports). For each of the three different macro types of processing, the compendium identifies the specific legal bases, roles, responsibilities, and obligations of websites and apps and reminds of the necessity to adopt technical and organizational security measures aimed at reducing the risks of destruction, loss, alteration, unauthorized disclosure of data, or accidental or unlawful access. A specific section of the compendium is dedicated to the obligation for platforms to carry out a prior impact assessment regarding data processing that may present a high risk to the rights and freedoms of individuals. Finally, a paragraph is dedicated to the information to be provided to patients which, in accordance with the principles of fairness and transparency, must be simple and clear as well as concise, transparent, intelligible, and easily accessible.****

****Wiretaps, Guarantor for Privacy: green light for the inter-district digital archive****

Favorable opinion from the Guarantor for Privacy on the draft decree of the Ministry of Justice regulating the activation of the digital archive of wiretaps (ADI) at inter-district infrastructures and defining the times, methods, and security requirements for the migration and conferment of data. The archive - kept under the direction and supervision of the Public Prosecutor - stores the minutes, acts, and recordings of wiretaps ordered by individual Prosecutors. However, the Guarantor has requested the Ministry to clarify in the text the role of data controller performed by the Public Prosecutors, to dispel possible interpretative doubts and facilitate the exercise of rights by the interested parties. With the current ministerial act, the process is completed that has already seen the establishment of centralized digital infrastructures for wiretaps and the definition of technical requirements for data management within such systems, on which the Guarantor has expressed a favorable opinion respectively in September and December 2023. The text of the draft decree under examination by the Guarantor does not present critical issues from the perspective of data protection. It indeed incorporates the indications provided during the preliminary phase by the Authority and provides for the additional technical organizational measures for the operation of the system requested by the Guarantor in the December opinion. In particular, the functions performed by the Public Prosecutor have been clearly delineated: direction, organization, and supervision of wiretap activities and related data. Moreover, the necessary technical-organizational measures to ensure adequate security levels concerning the risks associated with data processing carried out in the digital archive have been detailed further.

****THE ACTIVITY OF THE GUARANTOR - FOR THOSE WHO WANT TO KNOW MORE****

The most important interventions and measures recently adopted by the Authority

Artificial Intelligence: The Guarantor for Privacy writes to Parliament and Government

It is necessary to identify independent and impartial supervisory Authorities – Press release of March 25, 2024

School: the Guarantor for Privacy at “Didacta Italia” to design an educational path dedicated to the youngest – Press release of March 19, 2024

Guarantor for Privacy, opened investigation on drones at Elkann's house – Press release of March 18, 2024

Telemarketing, Guarantor for Privacy: the Code of conduct is underway. The Monitoring Body accredited for the full effectiveness of the new rules – Press release of March 17, 2024

Artificial intelligence, the Guarantor for Privacy initiates investigation on “Sora” by OpenAI. Information requested from the company on the algorithm that creates short videos from a few lines of text – Press release of March 8, 2024

****NEWSLETTER of the Guarantor for the protection of personal data (Reg. at the Court of Rome no. 654 of November 28, 2002).****

Responsible Director: Baldo Meo.

Direction and editorial office: Guarantor for the protection of personal data, Piazza Venezia, no. 11 - 00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it